DFIR WireShark Emotet 5

Riyad Alshehri

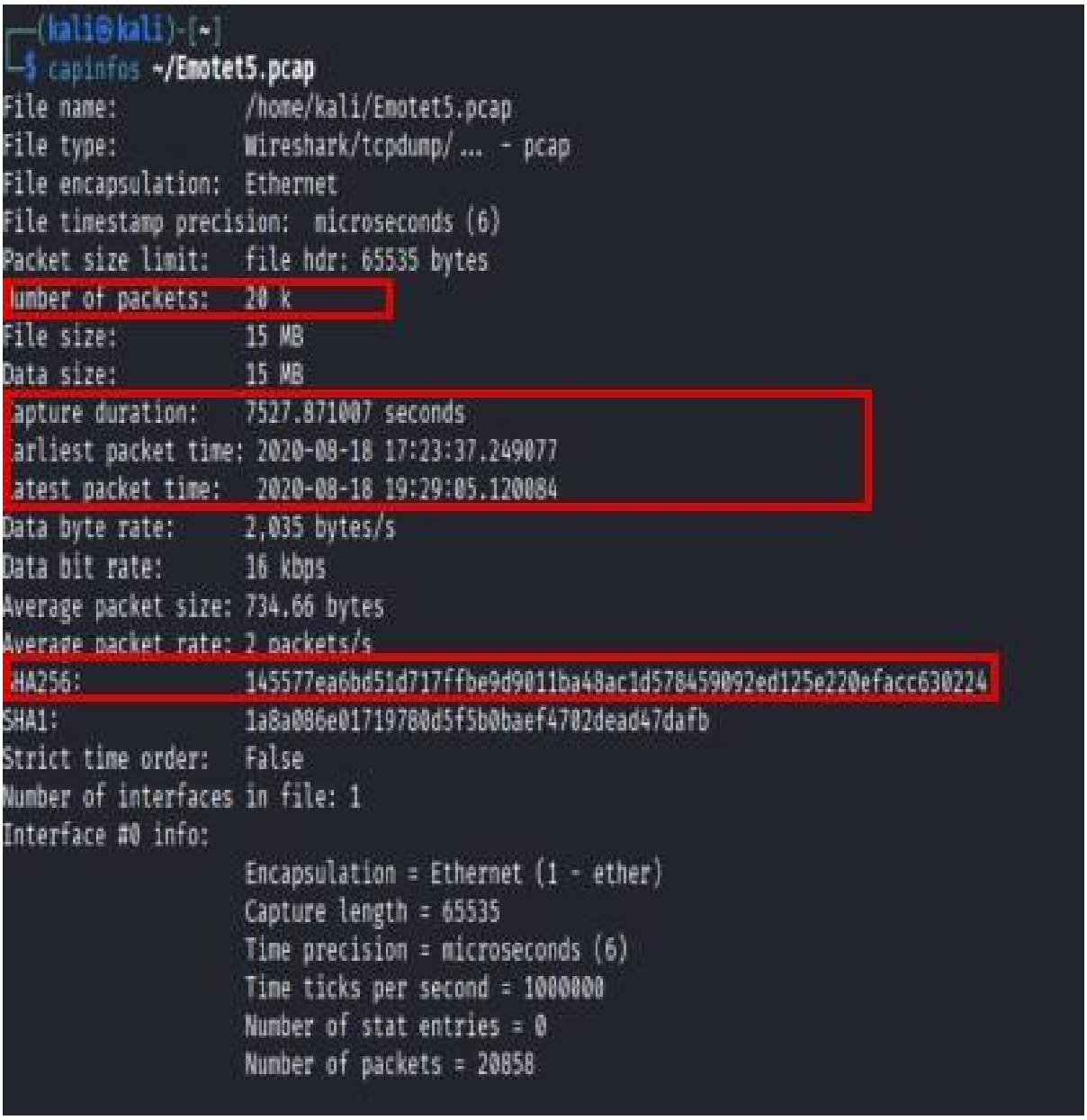
في هذا التاسك حللت ملف pcap فيه ترافيك جهاز مصاب ومشيت على نفس الترتيب: حفظ الدليل ثم الصورة العامة ثم هوية الضحية ثم DNS ثم HTTP ثم TLS.

1- حفظ الدليل

- نقلت الملف للكالي وشغلت capinfos وتأكدت ان الهاش نفس هاش الملف الاصلي.

- الملف فيه 20858 باكت ومدة التسجيل تقريبا ساعتين.

- الوقت في الصورة بتوقيت الكالي والوقت الفعلي بتوقيت UTC من 21:23 الى 23:29 يوم 18 اغسطس 2020.



2- الصورة العامة

- فتحت Statistics ثم Conversations ثم تبويب TCP ورتبت المحادثات حسب الحجم.

- الجهاز 192.168.100.101 موجود في كل المحادثات فهو الجهاز اللي بحقق فيه.

- اكبر محادثة كانت مع 71.80.66.107 على بورت 443 وحجمها 7 MB وهذا الـ IP يتكرر في القائمة اكثر من مرة.

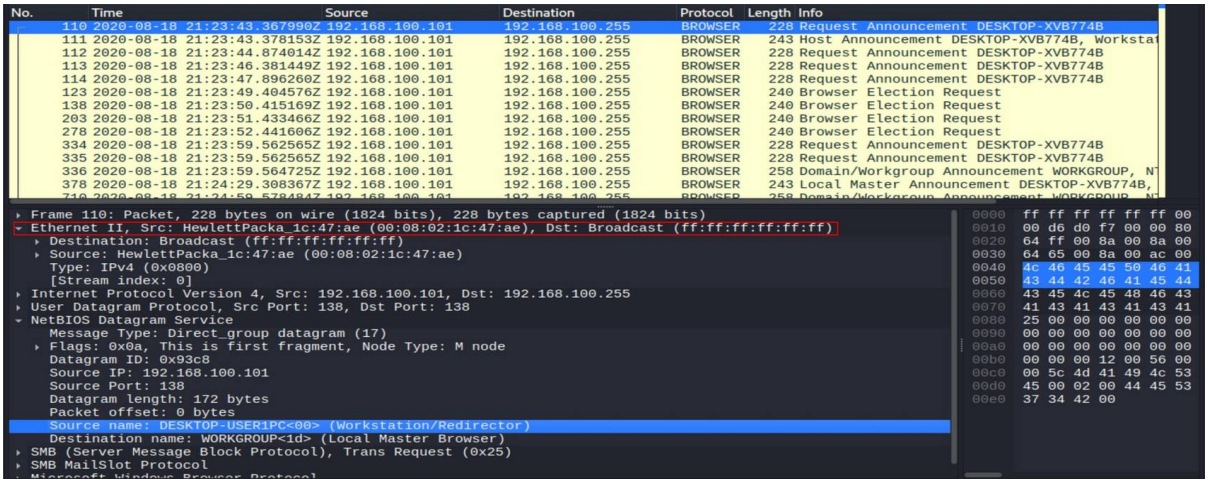
- بعدها 82.163.245.38 على بورت 80 وحجمها 1 MB وبرضو يتكرر اكثر من مرة.

- كل الاتصالات على بورت 80 و443 فما فيه بورتات غريبة وعشان كذا لازم اشوف المحتوى نفسه.

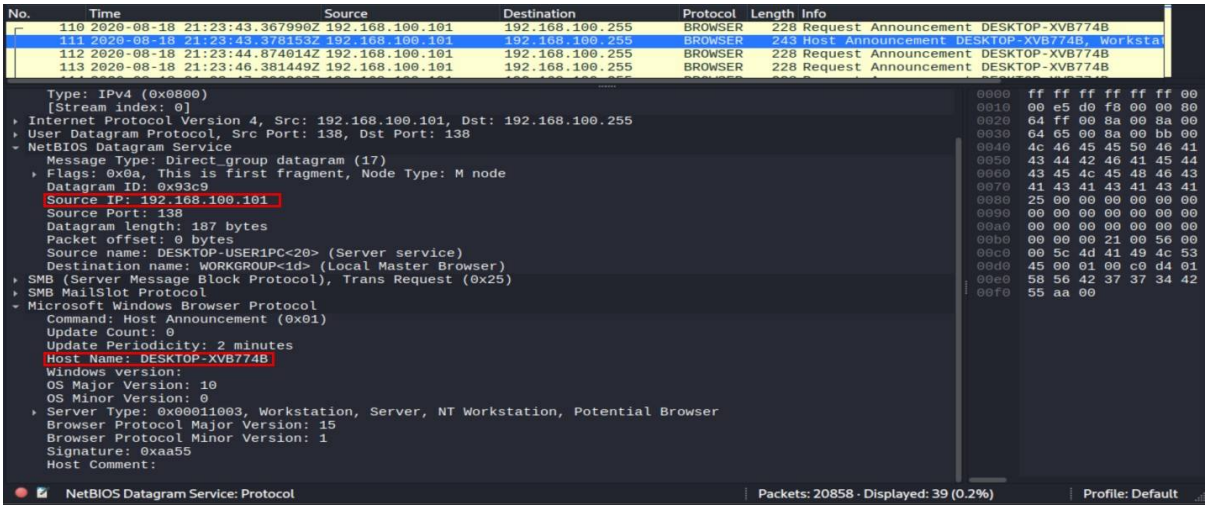
Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A
192.168.100.101	49746	71.80.66.107	443	7,973	7 MB	69	3,347	202 kB	4,626
192.168.100.101	49685	82.163.245.38	80	1,298	1 MB	11	468	72 kB	830
192.168.100.101	49750	71.80.66.107	443	1,233	977 kB	73	553	34 kB	680
192.168.100.101	49762	71.80.66.107	443	1,151	896 kB	85	527	33 kB	624
192.168.100.101	49756	71.80.66.107	443	1,015	800 kB	79	459	29 kB	556
192.168.100.101	49764	71.80.66.107	443	953	738 kB	87	440	27 kB	513
192.168.100.101	49779	208.80.153.224	443	529	480 kB	100	181	15 kB	348
192.168.100.101	49752	71.80.66.107	443	542	450 kB	75	223	14 kB	319
192.168.100.101	49835	82.163.245.38	80	478	430 kB	153	186	32 kB	292
192.168.100.101	49760	71.80.66.107	443	347	269 kB	83	150	10 kB	197
192.168.100.101	49780	208.80.153.240	443	295	252 kB	102	113	10 kB	182
192.168.100.101	49814	82.163.245.38	80	213	193 kB	132	82	16 kB	131
192.168.100.101	49854	82.163.245.38	80	149	142 kB	172	52	14 kB	97
192.168.100.101	49786	208.80.153.224	443	122	122 kB	107	32	3 kB	90
192.168.100.101	49675	166.62.28.83	80	112	110 kB	3	32	2 kB	80
192.168.100.101	49808	71.80.66.107	443	128	100 kB	126	79	96 kB	49
192.168.100.101	49743	71.80.66.107	443	128	97 kB	66	77	93 kB	51
192.168.100.101	49684	43.255.154.32	443	96	88 kB	10	32	2 kB	64
192.168.100.101	49702	104.45.177.233	443	117	78 kB	28	55	30 kB	62
192.168.100.101	49796	71.80.66.107	443	120	76 kB	115	56	4 kB	64
192.168.100.101	49797	72.21.81.200	443	53	39 kB	116	24	4 kB	29
192.168.100.101	49812	71.80.66.107	443	57	34 kB	130	33	31 kB	24
192.168.100.101	49705	40.91.76.238	443	44	24 kB	31	20	7 kB	24
192.168.100.101	49709	40.91.76.238	443	44	24 kB	35	22	8 kB	22

3- هوية الضحية

- استخدمت فلتر nbdgm وطلع لي الماك 00:08:02:1c:47:ae.



- وفي الباكت Host Announcement طلع اسم الجهاز DESKTOP-XVB774B في حقل Host Name.



- الجهاز في WORKGROUP مو في دومين وفلتر kerberos.CNameString ما طلع شي فما قدرت احدد اسم اليوزر من الترافيك.

يعني الضحية:

- IP: 192.168.100.101

- MAC: 00:08:02:1c:47:ae

- Hostname: DESKTOP-XVB774B

- Workgroup: WORKGROUP

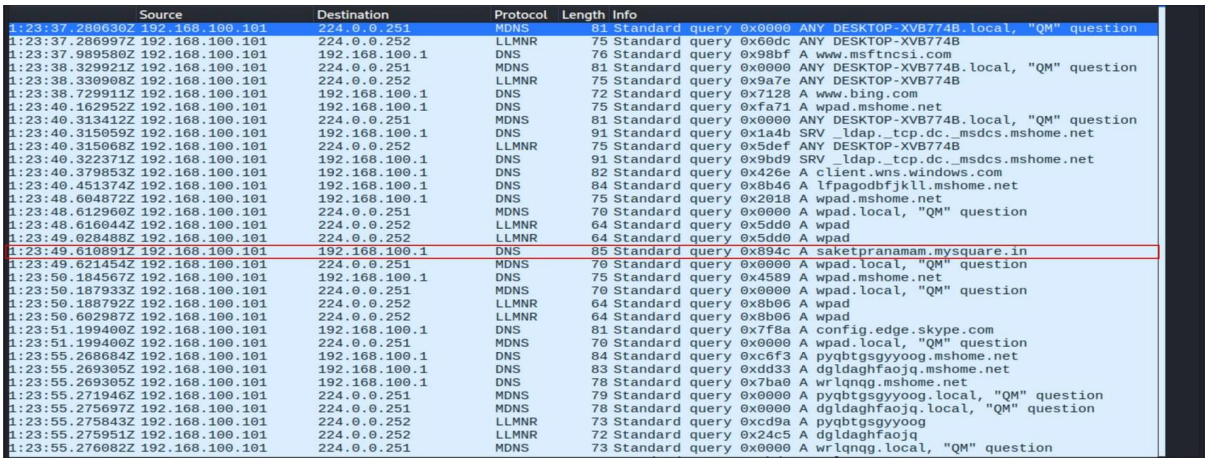
DNS -4

- استخدمت فلتر dns.flags.response == 0 عشان اعرض استعلامات DNS اللي طلعت من الجهاز بدون الردود.

- اغلب الاستعلامات لخدمات ويندوز ومايكروسوفت وقوقل وهذا ترافيك طبيعي.

- عند 21:23:49 بعد بداية التسجيل بثواني ظهر استعلام عن دومين غريب saketpranamam.mysquare.in.

- والـ IP الكبيرة 71.80.66.107 و 82.163.245.38 ما لها اي استعلام DNS يعني الجهاز اتصل فيها مباشرة بالـ IP.



Source	Destination	Protocol	Length	Info
1:23:37.280630Z 192.168.100.101	224.0.0.251	MDNS	81	Standard query 0x0000 ANY DESKTOP-XVB774B.local, "QM" question
1:23:37.286997Z 192.168.100.101	224.0.0.252	LLMNR	75	Standard query 0x60dc ANY DESKTOP-XVB774B
1:23:37.989580Z 192.168.100.101	192.168.100.1	DNS	76	Standard query 0x98bf A www.msftncsi.com
1:23:38.329921Z 192.168.100.101	224.0.0.251	MDNS	81	Standard query 0x0000 ANY DESKTOP-XVB774B.local, "QM" question
1:23:38.330908Z 192.168.100.101	224.0.0.252	LLMNR	75	Standard query 0x9a7e ANY DESKTOP-XVB774B
1:23:38.729911Z 192.168.100.101	192.168.100.1	DNS	72	Standard query 0x7128 A www.bing.com
1:23:40.162952Z 192.168.100.101	192.168.100.1	DNS	75	Standard query 0xfa71 A wpad.mshome.net
1:23:40.313412Z 192.168.100.101	224.0.0.251	MDNS	81	Standard query 0x0000 ANY DESKTOP-XVB774B.local, "QM" question
1:23:40.315059Z 192.168.100.101	192.168.100.1	DNS	91	Standard query 0x1a4b SRV _ldap._tcp.dc._msdcs.mshome.net
1:23:40.315068Z 192.168.100.101	224.0.0.252	LLMNR	75	Standard query 0x5def ANY DESKTOP-XVB774B
1:23:40.322371Z 192.168.100.101	192.168.100.1	DNS	91	Standard query 0x9bd9 SRV _ldap._tcp.dc._msdcs.mshome.net
1:23:40.379853Z 192.168.100.101	192.168.100.1	DNS	82	Standard query 0x426e A client.wns.windows.com
1:23:40.451374Z 192.168.100.101	192.168.100.1	DNS	84	Standard query 0x8b46 A lfpagodbfjkll.mshome.net
1:23:48.604872Z 192.168.100.101	192.168.100.1	DNS	75	Standard query 0x2018 A wpad.mshome.net
1:23:48.612960Z 192.168.100.101	224.0.0.251	MDNS	70	Standard query 0x0000 A wpad.local, "QM" question
1:23:48.616044Z 192.168.100.101	224.0.0.252	LLMNR	64	Standard query 0x5dd0 A wpad
1:23:49.028488Z 192.168.100.101	224.0.0.252	LLMNR	64	Standard query 0x5dd0 A wpad
1:23:49.610891Z 192.168.100.101	192.168.100.1	DNS	85	Standard query 0x894c A saketpranamam.mysquare.in
1:23:49.621454Z 192.168.100.101	224.0.0.251	MDNS	70	Standard query 0x0000 A wpad.local, "QM" question
1:23:50.184567Z 192.168.100.101	192.168.100.1	DNS	75	Standard query 0x4589 A wpad.mshome.net
1:23:50.187933Z 192.168.100.101	224.0.0.251	MDNS	70	Standard query 0x0000 A wpad.local, "QM" question
1:23:50.188792Z 192.168.100.101	224.0.0.252	LLMNR	64	Standard query 0x8b06 A wpad
1:23:50.602987Z 192.168.100.101	224.0.0.252	LLMNR	64	Standard query 0x8b06 A wpad
1:23:51.199400Z 192.168.100.101	192.168.100.1	DNS	81	Standard query 0x7f8a A config.edge.skype.com
1:23:51.199400Z 192.168.100.101	224.0.0.251	MDNS	70	Standard query 0x0000 A wpad.local, "QM" question
1:23:55.268684Z 192.168.100.101	192.168.100.1	DNS	84	Standard query 0xc6f3 A pyqbtgsgyyoog.mshome.net
1:23:55.269305Z 192.168.100.101	192.168.100.1	DNS	83	Standard query 0xdd33 A dgldaghfaojq.mshome.net
1:23:55.269305Z 192.168.100.101	192.168.100.1	DNS	78	Standard query 0x7ba0 A wrlqnqg.mshome.net
1:23:55.271946Z 192.168.100.101	224.0.0.251	MDNS	79	Standard query 0x0000 A pyqbtgsgyyoog.local, "QM" question
1:23:55.275697Z 192.168.100.101	224.0.0.251	MDNS	78	Standard query 0x0000 A dgldaghfaojq.local, "QM" question
1:23:55.275843Z 192.168.100.101	224.0.0.252	LLMNR	73	Standard query 0xcd9a A pyqbtgsgyyoog
1:23:55.275951Z 192.168.100.101	224.0.0.252	LLMNR	72	Standard query 0x24c5 A dgldaghfaojq
1:23:55.276082Z 192.168.100.101	224.0.0.251	MDNS	73	Standard query 0x0000 A wrlqnqg.local, "QM" question

5- ملف Word الخبيث

- استخدمت فلتر "http.host == "saketpranamam.mysquare.in وفتحت Follow HTTP Stream على الطلب.

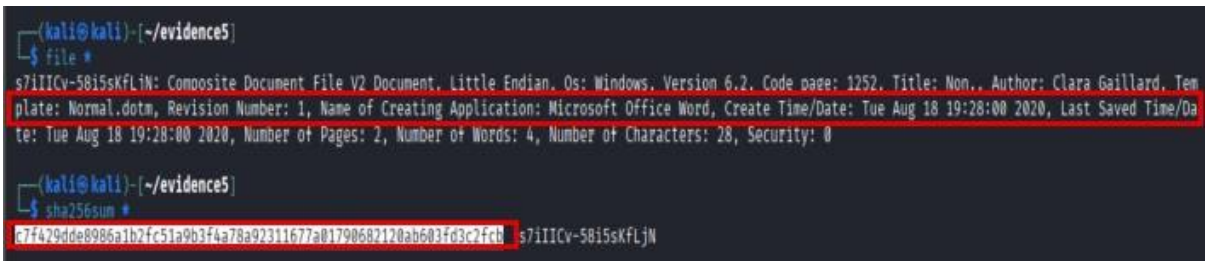
- الجهاز ارسل GET عن طريق متصفح Edge والسيرفر رد بملف Word اسمه MES_319254.doc ونوعه application/msword.



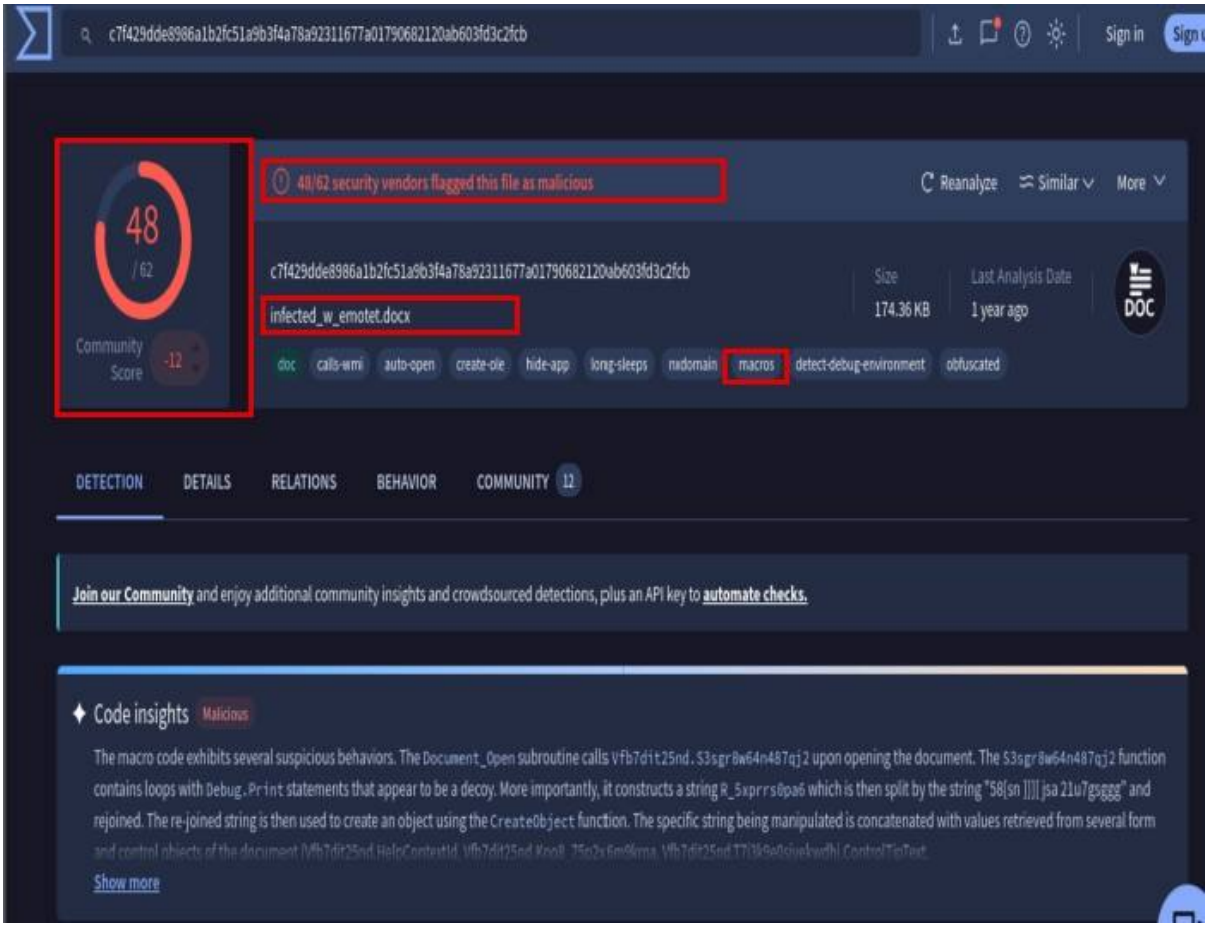
```
GET /temp/y32sa-q3lal-sector/security-area/s7iIICv-58i5sKfLjN/ HTTP/1.1
Host: saketpranamam.mysquare.in
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/84.0.4147.125 Safari/537.36 Edg/84.0
.522.61
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: en


HTTP/1.1 200 OK
Date: Tue, 18 Aug 2020 21:23:50 GMT
Server: Apache
X-Powered-By: PHP/7.4.8
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Expires: Tue, 18 Aug 2020 21:23:50 GMT
Content-Disposition: attachment; filename="MES_319254.doc"
Content-Transfer-Encoding: binary
Set-Cookie: 5f3c46e62e5b9=1597785830; expires=Tue, 18-Aug-2020 21:24:50 GMT; Max-Age=60; path=/
Upgrade: h2,h2c
Connection: Upgrade, Keep-Alive
Last-Modified: Tue, 18 Aug 2020 21:23:50 GMT
Vary: Accept-Encoding,User-Agent
Content-Encoding: gzip
Keep-Alive: timeout=5
Transfer-Encoding: chunked
Content-Type: application/msword
```

- طلعت الملف من File ثم Export Objects ثم HTTP وشغلت عليه file و sha256sum وطلع انه مستند Word.



- حطيت الهاش في VirusTotal وطلع 48/62 خبيث ومعروف باسم infected_w_emotet.docx وفيه Macros.



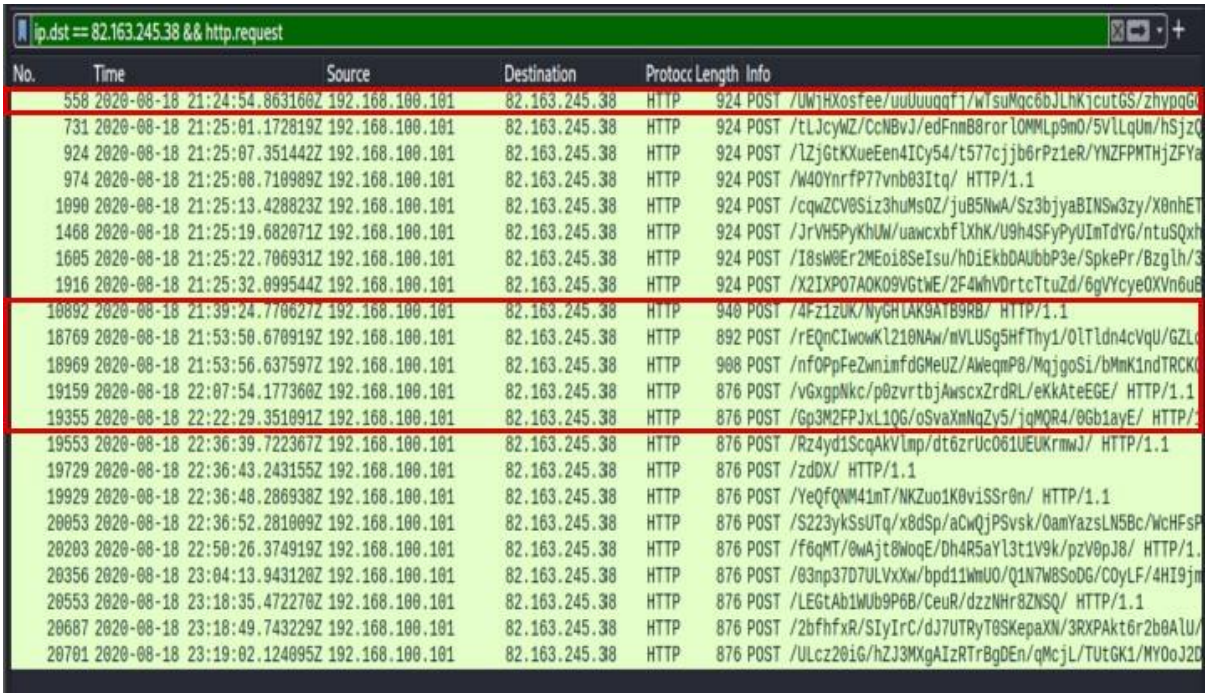
6- اتصالات C2

- استخدمت فلتر ip.dst == 82.163.245.38 && http.request.

- اول طلب كان عند 21:24:54 يعني بعد تنزيل ملف Word بدقيقة وحدة.

- كل الطلبات POST والمسارات عشوائية وبعد اول دفعة صار الجهاز يتواصل معه بشكل منتظم 21:39 ثم 21:53 ثم 22:07 ثم 22:22 يعني كل 15 دقيقة تقريبا.

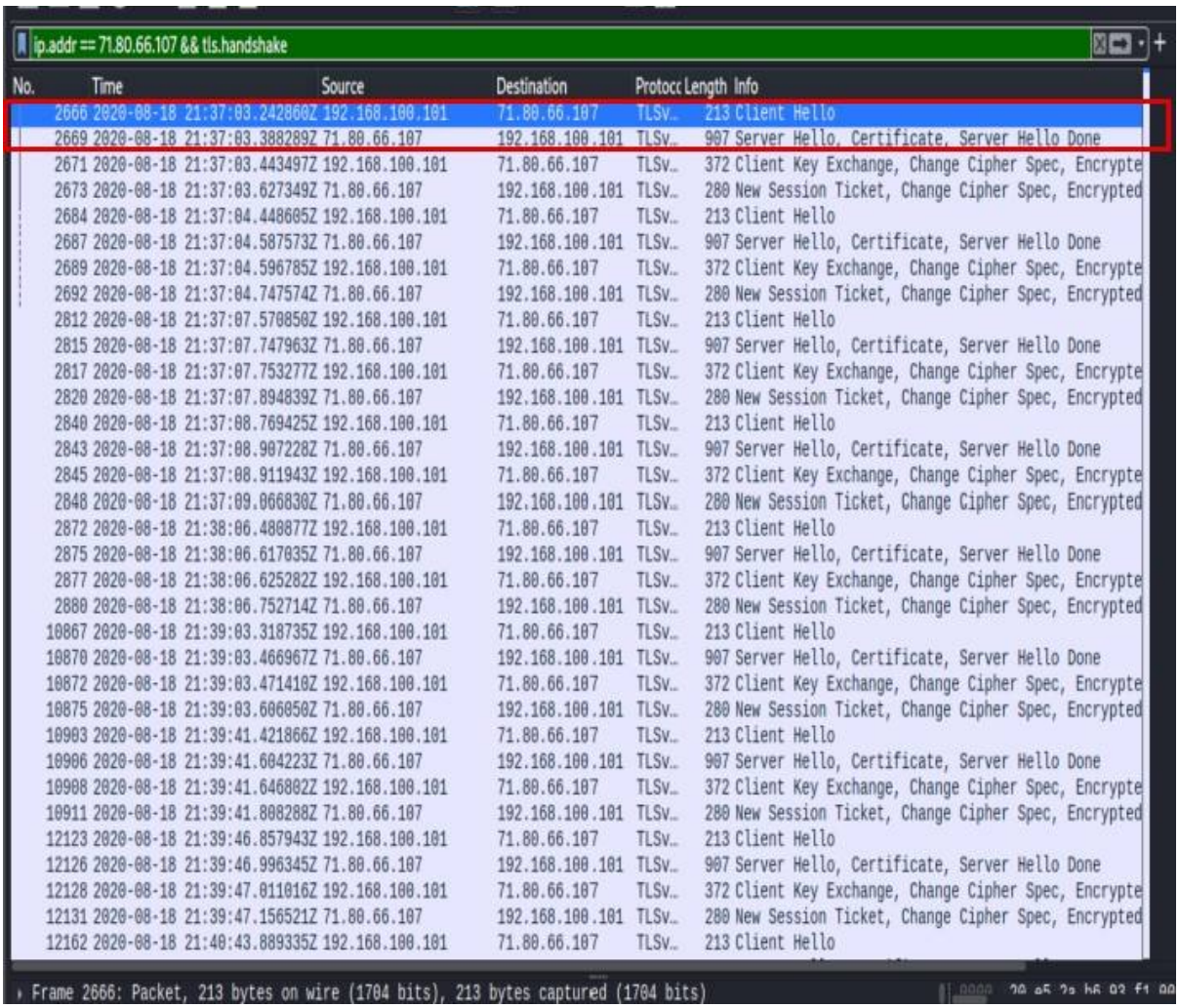
- وهذا نمط C2 Beaconing يعني البرنامج يتواصل مع سيرفر المهاجم كل فترة وبنفس الاسلوب كان يتواصل مع 45.55.82.2 على بورت 8080.



TLS -7

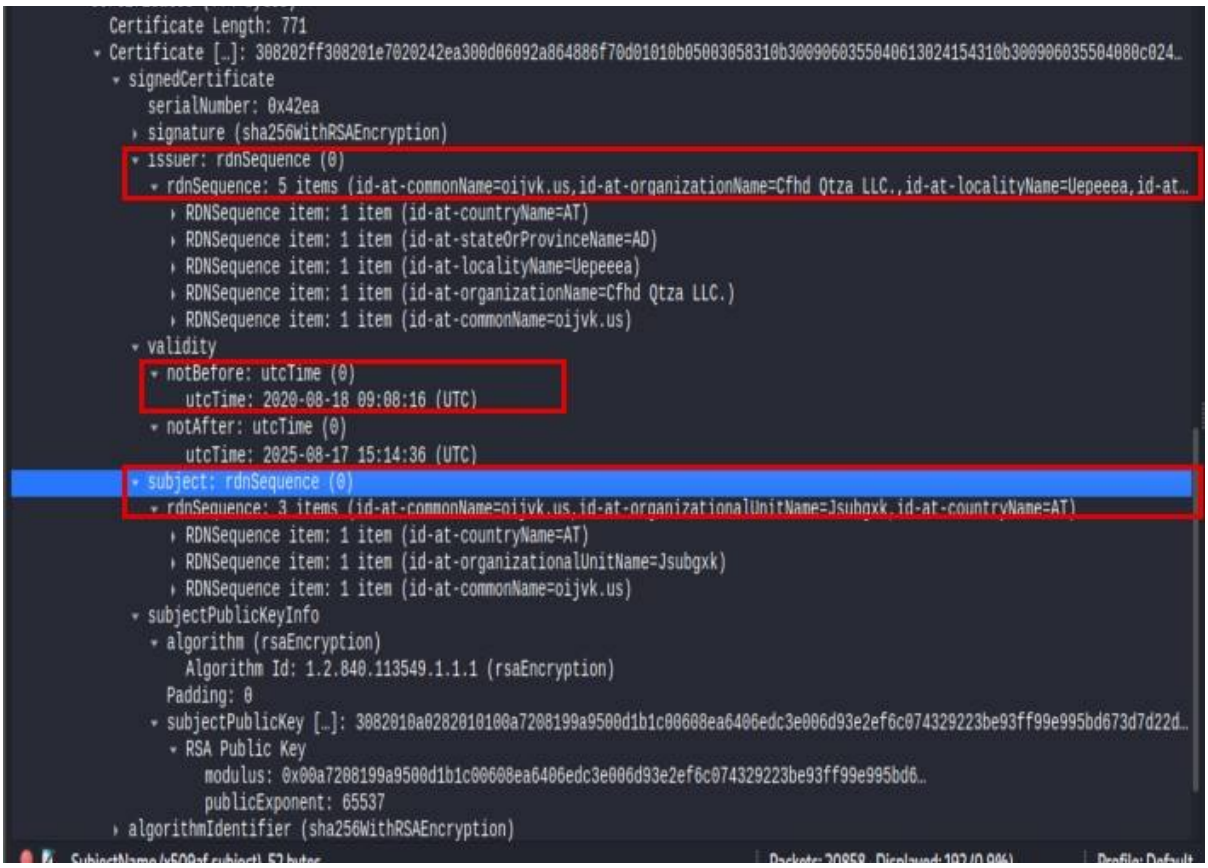
- اكبر محادثة مع 71.80.66.107 على بورت 443 مشفرة فاستخدمت فلتر ip.addr == 71.80.66.107 && tls.handshake عشان اشوف بداية الاتصال.

- اول اتصال كان عند 21:37:03 بعد بداية اتصالات C2 والجهاز يفتح اتصالات جديدة معه بشكل متكرر.

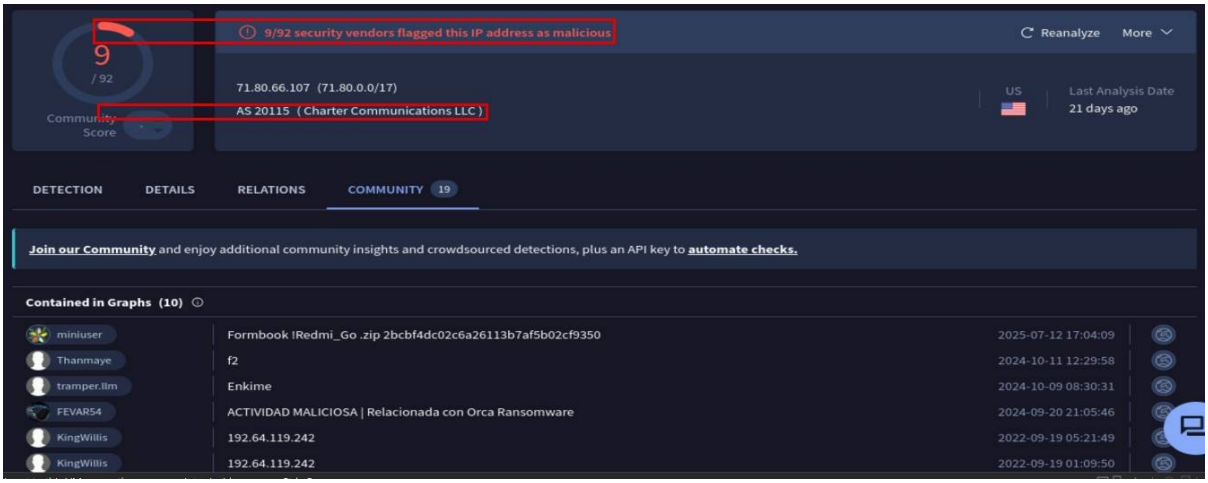


- فتحت الشهادة في الباكت 2669 ولقيت الـ issuer والـ subject نفس الاسم oijvk.us يعني الشهادة Self-signed.

- واسماء الشهادة عشوائية Cfhd Qtza LLC و Uepeeea وتاريخ اصدارها 2020-08-18 نفس يوم الاصابة.



- حطيت الـ IP في VirusTotal وطلع 9/92 خبيث.



الخلاصة

المستخدم على الجهاز DESKTOP-XVB774B نزل ملف Word خبيث اسمه MES_319254.doc من saketpranamam.mysquare.in والملف فيه Macros ومصنف Emotet في VirusTotal. بعد دقيقة من التنزيل بدأ الجهاز يتواصل مع سيرفرات C2 كل 15 دقيقة تقريبا لين اخر التسجيل. وبعدها بدأ اتصالات مشفرة متكررة مع 71.80.66.107 بشهادة Self-signed فيها اسماء عشوائية وهي اكبر محادثة في الملف.

التسلسل الزمني (UTC):

- 21:23:50 تنزيل ملف MES_319254.doc من saketpranamam.mysquare.in

- 21:24:54 اول اتصال C2 مع 82.163.245.38
- 21:25:02 اول اتصال C2 مع 45.55.82.2 على بورت 8080
- 21:37:03 اول اتصال TLS مع 71.80.66.107
- 23:19 اخر اتصال C2 في التسجيل

IOCs

- saketpranamam.mysquare.in نزل منه ملف Word الخبيث
- MES_319254.doc SHA256: c7f429dde8986a1b2fc51a9b3f4a78a92311677a01790682120ab603fd3c2fcb
- 82.163.245.38 بورت 80 سيرفر C2
- 45.55.82.2 بورت 8080 سيرفر C2
- 71.80.66.107 بورت 443 اتصالات مشفرة بشهادة Self-signed

التوصيات

- عزل الجهاز 192.168.100.101 عن الشبكة.
- حظر الـ IP والدومين المذكورة في الـ IOCs على الفايروول.
- حذف الملف MES_319254.doc وفحص الجهاز ببرنامج حماية.
- تعطيل تشغيل Macros في ملفات Office اللي جاية من الانترنت.
- توعية المستخدمين بعدم فتح الروابط والمرفقات المجهولة.